개인정보보호위원회 보도자료 다시 대한민국! 새로운 국민의 나라

보도시점 2023. 7. 12.(수) 14:00 배포 2023. 7. 12.(수) 13:40

개인정보위, ㈜엘지유플러스 개인정보 유출사고에 대해 과징금 68억 원, 과태료 2,700만 원 및 시정명령 부과

개인정보보호위원회(위원장 고학수, 이하 '개인정보위')는 7월 12일 전체회의를 개최하여 개인정보 유출사고가 발생한 **㈜엘지유플러스에 대해 과징금 68억 원과 함께 과태료 2,700만 원을 부과하고, 전반적인 시스템 점검 및 취약 부분 개선 등 재발 방지를 위한 시정조치(안)을 의결**하였다.

지난 1월 해커에 의해 불법거래 사이트에 개인정보 약 60만 건(중복 제거시 약 30만 건)이 공개된 **㈜엘지유플러스에 대해**, 그동안 **개인정보위는 민관 합동조사단·경찰 등과 협조하여 조사를 진행***해 왔다.

* 민·관 합동조사단은 「LGU+ 침해사고 원인분석 및 조치방안」 결과 발표(4.27)

개인정보위와 한국인터넷진흥원(원장 이원태, 이하 'KISA')이 분석한 결과, **유출이 확인된 개인정보는 총 297,117건(중복제거시)**으로 **유출 항목은** 휴대전화번호·성명·주소·생년월일·이메일주소·아이디·USIM고유번호 등 **26개의 항목**이며, ㈜엘지유플러스의 여러 시스템 중 **유출된 데이터**와 가장 일치하는 데이터를 **보관하는 시스템은 고객인증시스템(CAS)인 점**과, **유출시점은 '18.6월 경**인것으로 분석·확인되었다.

* 고객인증 시스템(CAS, Compound Authorization System) : ㈜엘지유플러스의 일부 부가서비스 제공과정에서 고객인증과 부가서비스 가입·해지 기능을 제공하는 시스템

지난 1월부터 ㈜엘지유플러스의 개인정보 처리·운영 실태와 개인정보 보호법 준수여부를 조사한 결과, 확인된 주요 위반사항은 다음과 같다.

첫째, 조사가 시작된 ’23.1월까지 고객인증시스템(CAS)의 서비스 운영 기반 시설(인프라)과 보안 환경은 해커 등의 불법침입에 매우 취약한 상황이었다.

고객인증시스템(CAS)의 운영체제(OS), 데이터베이스 관리시스템(DBMS), 웹서버(WEB), 웹 어플리케이션 서버(WAS) 등 상용 소프트웨어 대부분이 유출이 발생한 것으로 추정되는 ’18.6월 기준으로 단종되거나 기술지원이 종료된 상태였다.

또, 불법침입과 침해사고 방지에 필요한 **침입차단시스템(방화벽), 침입방지시스템(IPS), 웹방화벽 등 기본적인 보안장비가 설치되지 않았거나 설치 중이더라도 보안정책이 제대로 적용되지 않았고, 일부는 기술지원이 중단된 상태**였다.

특히, **고객인증시스템(CAS)** 개발기에 ’09년과 ’18년에 업로드된 **악성코드(웹셸)가 ’23.1월까지 삭제되지 않고 남아 있었고, 웹셸에 대한 점검이나 IPS의 웹셸 탐지·차단 정책은 적용되지 않고 있었다.**

둘째, 고객인증시스템(CAS) 운영기에서 관리하는 실제 운영 데이터(개인정보 포함)를 개발기, 검수기로 옮겨 테스트를 진행한 후, 일부 데이터를 방치해 ’08년에 생성된 정보 등 **1천만 건 이상의 개인정보가 조사 시점까지 남아 있었다.**

* ㈜엘지유플러스는 고객인증시스템(CAS)을 개발기, 검수기, 운영기로 나눠서 운영

셋째, 다량의 개인정보를 관리하면서도, 개인정보취급자의 접근권한과 접속기록을 제대로 관리하지 않아, 대규모 개인정보를 추출·전송한 기록을 남기지 않고 비정상 행위 여부에 대한 점검·확인이 안되는 등 **관리 통제도 부실한 상황**이었다.

㈜엘지유플러스는 다수 국민의 개인정보를 처리하는 유·무선 통신사업자로서 엄격한 개인정보 관리가 요구됨에도 불구하고, 고객인증(CAS) 시스템의 전반적인 관리 부실과 함께 타사 대비 현저히 저조한 정보보호·보안 관련 투자와 노력 부족이 금번 개인정보 유출사고로 이어졌다고 판단해, 개인정보위는 ㈜엘지유플러스에 대해 **보호법 위반으로 과징금과 과태료를 부과하기로 결정하였다.**

아울러, 최근 3년간 보호법 위반사실*이 존재하는 ㈜엘지유플러스에 대해 **개인정보보호책임자**(CPO, Chief Privacy Officer)의 **역할과 위상 강화**, **개인정보 보호 조직의 전문성 제고**, 개인정보 **내부관리계획 재정립**, 전반적인 **시스템 점검 및 취약요소 개선** 등을 **시정명령** 하기로 하면서, 지난 1월 사고 이후 ㈜엘지유플러스에서 약속한 개인정보 보호 관련 각종 **투자와 2차 피해 방지 대책을 차질 없이 이행할 것을 당부**하였다.

* 수탁자에 대한 관리·감독 소홀, 개인정보 보호조치(접근통제) 위반으로 과징금·과태료 처분('20.12.9)

이번 조치는 '18.6월경 발생한 유출로 분석되었으나, **현재까지 지속된 해당 시스템 관리의 전반적 부실 및 다수의 법규위반으로 과징금이 부과된 건**으로, 평소 다량의 개인정보를 보유·처리하는 사업자의 경우 **개인정보 보호 관련 예산·인력의 투입을 비용이 아닌 투자로 파악하는 전기가 될 것**으로 기대한다. 또한, 데이터 경제시대 **개인정보 보호 관련 최고책임자(CPO) 및 조직**이 기업경영에서 차지하는 **역할과 중요성에 대해 재고하게 되는 계기**가 될 것으로 기대한다.

담당 부서 <총괄>	조사조정국 조사2과	책임자	과 장	김해숙 (02-2100-3121)
		담당자	사무관	문인수 (02-2100-3126)
<공동>	한국인터넷진흥원 개인정보조사단	책임자	단 장	차윤호 (061-820-1830)
		담당자	팀 장	문봉주 (061-820-1496)

대한민국 정책브리핑 OPEN 출처표시 공공누리 공공저작물 자유이용허락

참고1 위반사항에 대한 행정처분 내용

연번	사업자명	위반항목	위반내용	위반조항	시정조치(안)
1	㈜엘지 유플러스	개인정보의 파기	• 개인정보가 불필요하게 되었을 때 지체 없이 개인정보를 파기하지 않음	법§21① 영§16	• 과징금 68억 45만 2천 원 • 과태료 2,700만 원 • 시정조치 명령 • 결과 공표
		안전조치 의무	- 개인정보처리시스템 접근권한 부여·변경·말소 내역 보관을 소홀히 함	법§29 영§48조의2 고시§4	
			- 침입차단·탐지시스템 운영을 소홀히 함		
			- 비밀번호 작성규칙 적용을 하지 않음		
			- 접속기록 보존·관리를 소홀히 함	법§29 영§48조의2 고시§5	
		유출신고·통지	• 24시간 이내 유출통지하지 않음	법§39조의4① 영§48조의4	

참고2 개인정보 보호법

*** 보호법 제21조(개인정보의 파기)**

① 개인정보처리자는 보유기간의 경과, 개인정보의 처리 목적 달성 등 그 개인정보가 불필요하게 되었을 때에는 지체 없이 그 개인정보를 파기하여야 한다. 다만, 다른 법령에 따라 보존하여야 하는 경우에는 그러하지 아니하다.

*** 보호법 제29조(안전조치의무)**

개인정보처리자는 개인정보가 분실・도난・유출・위조・변조 또는 훼손되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적・관리적 및 물리적 조치를 하여야 한다.

*** 보호법 제39조의4(개인정보 유출등의 통지・신고에 대한 특례)**

① 제34조제1항 및 제3항에도 불구하고 정보통신서비스 제공자와 그로부터 제17조제1항에 따라 이용자의 개인정보를 제공받은 자(이하 "정보통신서비스 제공자등"이라 한다)는 개인정보의 분실・도난・유출(이하 "유출등"이라 한다) 사실을 안 때에는 지체 없이 다음 각 호의 사항을 해당 이용자에게 알리고 보호위원회 또는 대통령령으로 정하는 전문기관에 신고하여야 하며, 정당한 사유 없이 그 사실을 안 때부터 24시간을 경과하여 통지・신고해서는 아니 된다. 다만, 이용자의 연락처를 알 수 없는 등 정당한 사유가 있는 경우에는 대통령령으로 정하는 바에 따라 통지를 갈음하는 조치를 취할 수 있다.

1. 유출등이 된 개인정보 항목
2. 유출등이 발생한 시점
3. 이용자가 취할 수 있는 조치
4. 정보통신서비스 제공자등의 대응 조치
5. 이용자가 상담 등을 접수할 수 있는 부서 및 연락처